

Noxious | HackTheBox Writeup

Written by: Alexander Sapo

Date: 7/29/26



Sherlock Scenario

The IDS device alerted us to a possible rogue device in the internal Active Directory network. The Intrusion Detection System also indicated signs of LLMNR traffic, which is unusual. It is suspected that an LLMNR poisoning attack occurred. The LLMNR traffic was directed towards Forela-WKstn002, which has the IP address 172.17.79.136. A limited packet capture from the surrounding time is provided to you, our Network Forensics expert. Since this occurred in the Active Directory VLAN, it is suggested that we perform network threat hunting with the Active Directory attack vector in mind, specifically focusing on LLMNR poisoning.

Task:

Task 1

It's suspected by the security team that there was a rogue device in Forela's internal network running responder tool to perform an LLMNR Poisoning attack. Please find the malicious IP Address of the machine.

flag:172.17.79.135

Task 2

What is the hostname of the rogue machine?

flag:kali

Task 3

Now we need to confirm whether the attacker captured the user's hash and it is crackable!!

What is the username whose hash was captured?

flag:john.deacon

Task 4

In NTLM traffic we can see that the victim credentials were relayed multiple times to the attacker's machine. When were the hashes captured the First time?

flag:2024-06-24 11:18:30

Task 5

What was the typo made by the victim when navigating to the file share that caused his credentials to be leaked?

flag:DCC01

Task 6

To get the actual credentials of the victim user we need to stitch together multiple values from the ntlm negotiation packets. What is the NTLM server challenge value?

flag:601019d191f054f1

Task 7

Now doing something similar find the NTProofStr value.

flag:c0cc803a6d9fb5a9082253a04dbd4cd4

Task 8

To test the password complexity, try recovering the password from the information found from packet capture. This is a crucial step as this way we can find whether the attacker was able to crack this and how quickly.

flag:NotMyPasswordOK?

Task 9

Just to get more context surrounding the incident, what is the actual file share that the victim was trying to navigate to?

flag:\\DC01\\DC-Confidential

Process Analysis

The attack analyzed in this investigation was **LLMNR Poisoning**, performed using **Responder**. This attack exploits the **Link-Local Multicast Name Resolution (LLMNR)** protocol to capture **NetNTLM challenge-response authentication** from systems on the local network.

Responder is an open-source, Python-based penetration testing tool that targets legacy Windows name resolution protocols, such as **LLMNR** and **NBT-NS**, to intercept authentication attempts and capture **NetNTLM challenge-response hashes**.

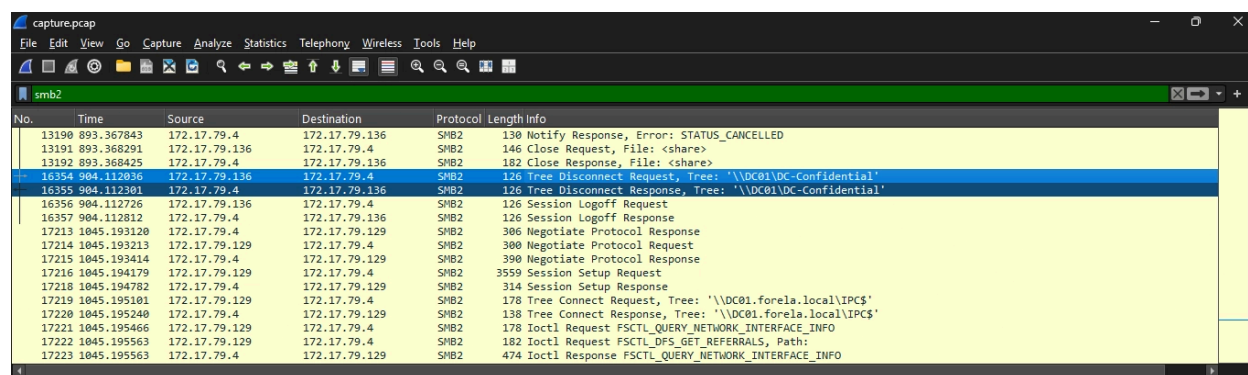
The objective of this analysis was to understand:

- The vulnerability exploited by the attacker.
- The complete attack sequence.
- The network traffic generated throughout the attack.
- Whether the captured credentials could be recovered through offline password cracking.

Attack Sequence

Based on the captured network traffic, the attack occurred in the following order.

1. Victim Attempts to Access a Network Share



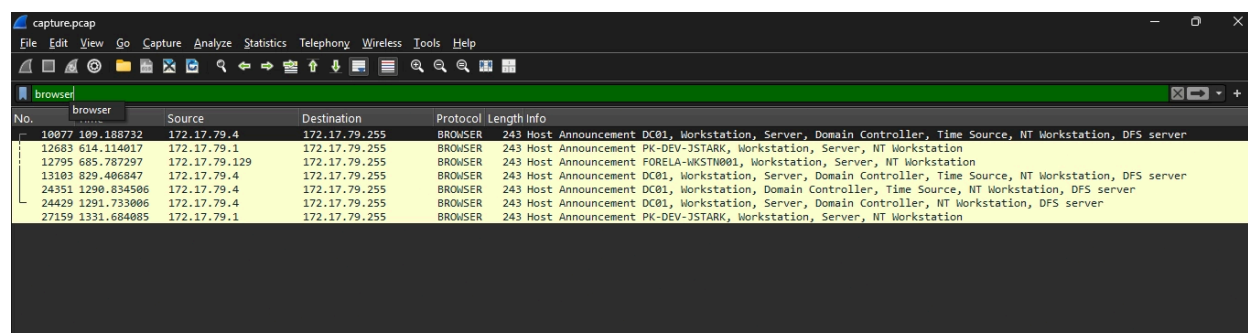
The screenshot shows a Wireshark capture of network traffic. The 'SMB2' filter is applied. The packet list shows several SMB2 messages. The packet details pane for packet 16354 (112036) is selected, showing a 'Tree Disconnect Request' for the tree '\\DCC01\DC-Confidential'. The packet bytes pane shows the raw data of the request.

No.	Time	Source	Destination	Protocol	Length	Info
13190	893.367843	172.17.79.4	172.17.79.136	SMB2	130	Notify Response, Error: STATUS_CANCELLED
13191	893.368291	172.17.79.136	172.17.79.4	SMB2	146	Close Request, File: <share>
13192	893.368425	172.17.79.4	172.17.79.136	SMB2	182	Close Response, File: <share>
16354	904.112036	172.17.79.136	172.17.79.4	SMB2	126	Tree Disconnect Request, Tree: '\\DCC01\DC-Confidential'
16355	904.112301	172.17.79.4	172.17.79.136	SMB2	126	Tree Disconnect Response, Tree: '\\DCC01\DC-Confidential'
16356	904.112726	172.17.79.136	172.17.79.4	SMB2	126	Session Logoff Request
16357	904.112812	172.17.79.4	172.17.79.136	SMB2	126	Session Logoff Response
17213	1045.193120	172.17.79.4	172.17.79.129	SMB2	306	Negotiate Protocol Response
17214	1045.193213	172.17.79.129	172.17.79.4	SMB2	300	Negotiate Protocol Request
17215	1045.193414	172.17.79.4	172.17.79.129	SMB2	390	Negotiate Protocol Response
17216	1045.194179	172.17.79.129	172.17.79.4	SMB2	3559	Session Setup Request
17218	1045.194782	172.17.79.4	172.17.79.129	SMB2	314	Session Setup Response
17219	1045.195101	172.17.79.129	172.17.79.4	SMB2	178	Tree Connect Request, Tree: '\\DCC01.forela.local\IPCS'
17220	1045.195240	172.17.79.4	172.17.79.129	SMB2	138	Tree Connect Response, Tree: '\\DCC01.forela.local\IPCS'
17221	1045.195466	172.17.79.129	172.17.79.4	SMB2	178	Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
17222	1045.195563	172.17.79.129	172.17.79.4	SMB2	182	Ioctl Request FSCTL_DFS_GET_REFERRALS, Path:
17223	1045.195563	172.17.79.4	172.17.79.129	SMB2	474	Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO

The victim workstation, **Forela-WKstn002** (**172.17.79.136**), attempted to access a shared file named:

```
\\DCC01\DC-Confidential
```

The shared resource **DC-Confidential** was actually hosted on the legitimate domain controller:



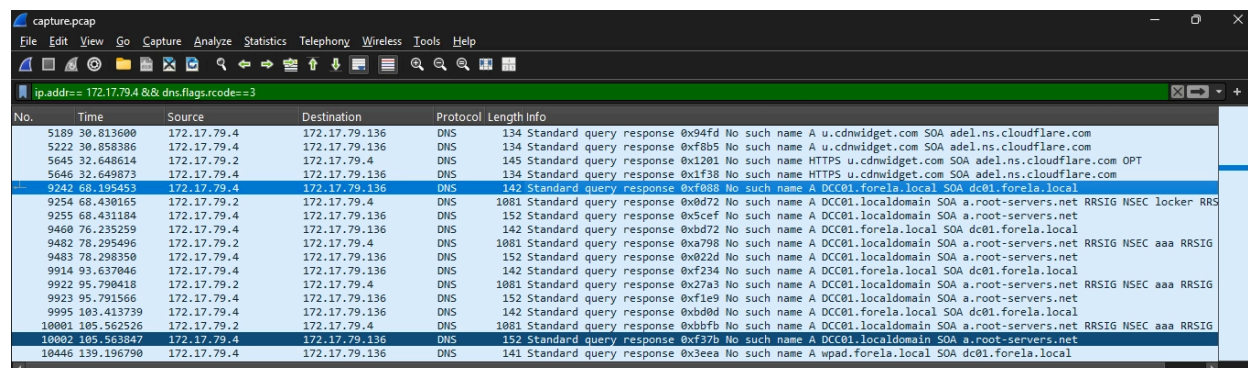
The image shows a Wireshark packet capture of browser traffic. The filter is 'browser'. The packet list shows several 'Host Announcement' messages from various IP addresses to 172.17.79.255. The packet details pane shows the 'Host Announcement' structure with fields like 'Host', 'Domain Controller', 'Time Source', and 'DPS server'.

No.	Time	Source	Destination	Protocol	Length	Info
10877	109.188732	172.17.79.4	172.17.79.255	BROWSER	243	Host Announcement DC01, Workstation, Server, Domain Controller, Time Source, NT Workstation, DFS server
12683	614.114017	172.17.79.1	172.17.79.255	BROWSER	243	Host Announcement PK-DEV-JSTARK, Workstation, Server, NT Workstation
12795	685.787297	172.17.79.129	172.17.79.255	BROWSER	243	Host Announcement FORELA-WKSTN001, Workstation, Server, NT Workstation
13103	829.406847	172.17.79.4	172.17.79.255	BROWSER	243	Host Announcement DC01, Workstation, Server, Domain Controller, Time Source, NT Workstation, DFS server
24351	1290.834506	172.17.79.4	172.17.79.255	BROWSER	243	Host Announcement DC01, Workstation, Domain Controller, Time Source, NT Workstation, DFS server
24429	1291.739006	172.17.79.4	172.17.79.255	BROWSER	243	Host Announcement DC01, Workstation, Server, Domain Controller, NT Workstation, DFS server
27159	1331.684085	172.17.79.1	172.17.79.255	BROWSER	243	Host Announcement PK-DEV-JSTARK, Workstation, Server, NT Workstation

- **Hostname:** DC01
- **IP Address:** 172.17.79.4

However, the user accidentally mistyped the hostname as **DCC01** instead of **DC01**.

2. DNS Resolution Failure



The image shows a Wireshark packet capture of DNS traffic. The filter is 'ip.addr == 172.17.79.4 && dns.flags.rcode == 3'. The packet list shows several 'Standard query response' messages from 172.17.79.136 to 172.17.79.4. The packet details pane shows the 'Standard query response' structure with fields like 'Question', 'Answer', 'Authority', and 'Additional'. The 'Answer' field shows 'No such name' for the requested hostnames.

No.	Time	Source	Destination	Protocol	Length	Info
5189	30.813600	172.17.79.4	172.17.79.136	DNS	134	Standard query response 0x4fd No such name A u.cdnwidget.com SOA adel.ns.cloudflare.com
5222	30.858386	172.17.79.4	172.17.79.136	DNS	134	Standard query response 0xf8b5 No such name A u.cdnwidget.com SOA adel.ns.cloudflare.com
5645	32.648614	172.17.79.2	172.17.79.4	DNS	145	Standard query response 0x1201 No such name HTTPS u.cdnwidget.com SOA adel.ns.cloudflare.com OPT
5646	32.649873	172.17.79.4	172.17.79.136	DNS	134	Standard query response 0x1f38 No such name HTTPS u.cdnwidget.com SOA adel.ns.cloudflare.com
9242	68.195453	172.17.79.4	172.17.79.136	DNS	142	Standard query response 0xf088 No such name A DCC01.forela.local SOA dc01.forela.local
9254	68.430165	172.17.79.2	172.17.79.4	DNS	1081	Standard query response 0xb072 No such name A DCC01.localdomain SOA a.root-servers.net RRSIG NSEC locker RRS
9255	68.431184	172.17.79.4	172.17.79.136	DNS	152	Standard query response 0x5cef No such name A DCC01.localdomain SOA a.root-servers.net
9460	76.235259	172.17.79.4	172.17.79.136	DNS	142	Standard query response 0xb072 No such name A DCC01.forela.local SOA dc01.forela.local
9482	78.295496	172.17.79.2	172.17.79.4	DNS	1081	Standard query response 0xb078 No such name A DCC01.localdomain SOA a.root-servers.net RRSIG NSEC aaa RRSIG
9483	78.298350	172.17.79.4	172.17.79.136	DNS	152	Standard query response 0x822d No such name A DCC01.localdomain SOA a.root-servers.net
9914	93.637046	172.17.79.4	172.17.79.136	DNS	142	Standard query response 0xf234 No such name A DCC01.forela.local SOA dc01.forela.local
9922	95.790418	172.17.79.2	172.17.79.4	DNS	1081	Standard query response 0x27a3 No such name A DCC01.localdomain SOA a.root-servers.net RRSIG NSEC aaa RRSIG
9923	95.791566	172.17.79.4	172.17.79.136	DNS	152	Standard query response 0xf1e9 No such name A DCC01.localdomain SOA a.root-servers.net
9995	103.413739	172.17.79.4	172.17.79.136	DNS	142	Standard query response 0xb00d No such name A DCC01.forela.local SOA dc01.forela.local
10001	105.562526	172.17.79.2	172.17.79.4	DNS	1081	Standard query response 0xb0bf No such name A DCC01.localdomain SOA a.root-servers.net RRSIG NSEC aaa RRSIG
10002	105.563847	172.17.79.4	172.17.79.136	DNS	152	Standard query response 0xf37b No such name A DCC01.localdomain SOA a.root-servers.net
10446	139.196790	172.17.79.4	172.17.79.136	DNS	141	Standard query response 0x3eea No such name A wpad.forela.local SOA dc01.forela.local

The victim first attempted to resolve the hostname using **DNS**.

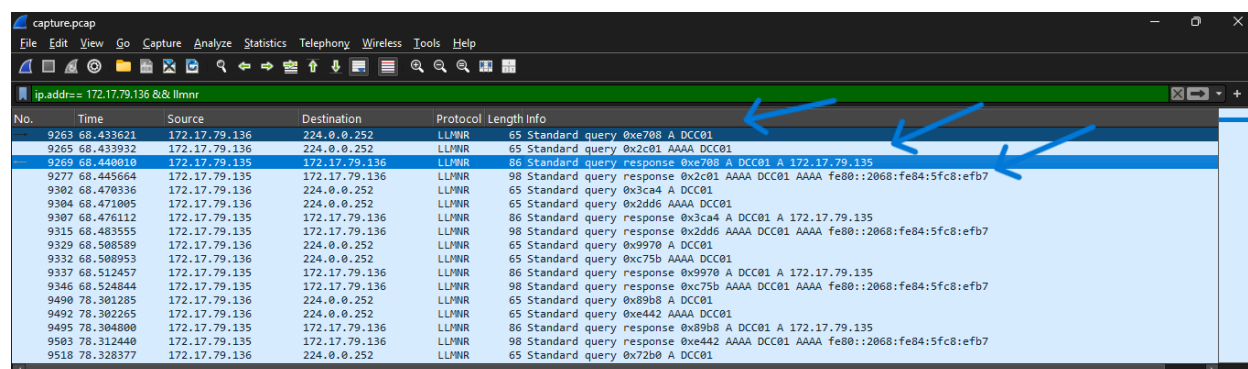
The DNS server returned a **"No such name"** response, indicating that the requested hostname did not exist.

Since Windows could not resolve the hostname through DNS, it automatically fell back to **LLMNR**.

3. LLMNR Broadcast

After the DNS failure, the victim broadcast an **LLMNR query** across the local network asking whether any device owned the hostname **DCC01**.

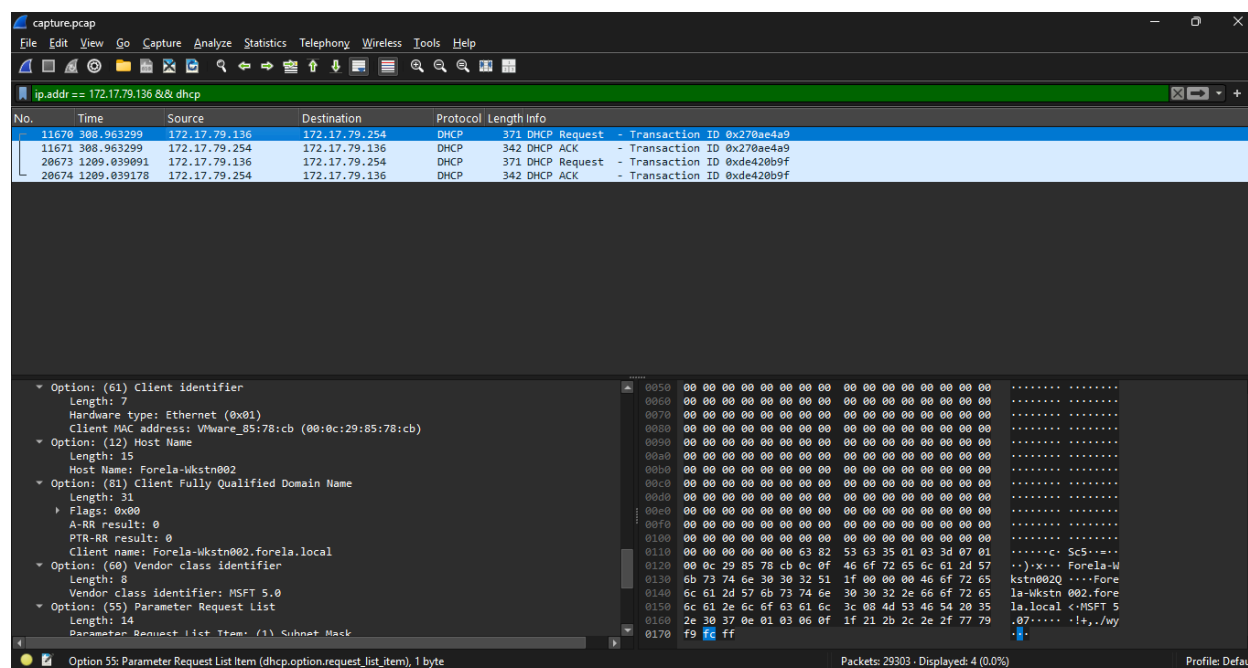
Because LLMNR is a multicast protocol and does not authenticate responses, **any host on the local network** can answer the request.



4. Attacker Spoofs the Requested Host

The attacker was running **Responder**, which continuously listens for LLMNR broadcasts.

The malicious system responded by falsely claiming ownership of the hostname **DCC01**, causing the victim to believe it had reached the intended server.



The attacker system was identified as:

Attribute	Value
IPv4 Address	172.17.79.135

Attribute	Value
IPv6 Address	fe80::2068:fe84:5fc8:efb7
Hostname (from DHCP traffic)	kali

5. NTLM Authentication Begins

The image shows a Wireshark packet capture of an NTLM authentication sequence. The filter is set to 'ipv6.addr==fe80:2068:fe84:5fc8:efb7 && smb2'. The packet list shows the following key events:

No.	Time	Source	Destination	Protocol	Length	Info
9278	68.448611	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	314	Negotiate Protocol Response
9279	68.449171	fe80::7994:1860:7111...	fe80::2068:fe84:5fc8:efb7	SMB2	296	Negotiate Protocol Request
9280	68.450228	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	314	Negotiate Protocol Response
9290	68.457671	fe80::7994:1860:7111...	fe80::2068:fe84:5fc8:efb7	SMB2	240	Session Setup Request, NTLMSSP_NEGOTIATE
9291	68.459009	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	412	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
9292	68.459907	fe80::7994:1860:7111...	fe80::2068:fe84:5fc8:efb7	SMB2	717	Session Setup Request, NTLMSSP_AUTH, User: FORELA\john.deacon
9293	68.463722	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	150	Session Setup Response, Error: STATUS_ACCESS_DENIED
9313	68.480733	fe80::7994:1860:7111...	fe80::2068:fe84:5fc8:efb7	SMB2	314	Negotiate Protocol Request
9316	68.485121	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	314	Negotiate Protocol Response
9317	68.486004	fe80::7994:1860:7111...	fe80::2068:fe84:5fc8:efb7	SMB2	240	Session Setup Request, NTLMSSP_NEGOTIATE
9319	68.490152	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	412	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
9320	68.490854	fe80::7994:1860:7111...	fe80::2068:fe84:5fc8:efb7	SMB2	717	Session Setup Request, NTLMSSP_AUTH, User: FORELA\john.deacon
9321	68.504725	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	150	Session Setup Response, Error: STATUS_ACCESS_DENIED
9343	68.518464	fe80::7994:1860:7111...	fe80::2068:fe84:5fc8:efb7	SMB2	314	Negotiate Protocol Request
9347	68.525236	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	240	Negotiate Protocol Response
9348	68.526392	fe80::7994:1860:7111...	fe80::2068:fe84:5fc8:efb7	SMB2	412	Session Setup Request, NTLMSSP_NEGOTIATE
9349	68.527029	fe80::2068:fe84:5fc8:efb7	fe80::7994:1860:7111...	SMB2	412	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE

Believing it was communicating with the legitimate server, the victim initiated **NTLMSSP authentication**.

The captured authentication sequence consisted of:

1. **NTLMSSP_NEGOTIATE**
2. **NTLMSSP_CHALLENGE**
3. **NTLMSSP_AUTH**

The first captured authentication occurred at:

UTC Timestamp

2024-06-24T11:18:30.919816000Z

or

2024-06-24 11:18:30 UTC

The authenticated user was:

john.deacon

Captured Authentication

During the NTLM authentication process, the attacker successfully captured the victim's **NetNTLMv2 challenge-response**.

The captured information included:

Field	Value
Username	john.deacon
Domain	FORELA
Server Challenge	601019d191f054f1
NTPProofStr	c0cc803a6d9fb5a9082253a04dbd4cd4

The attacker did **not** obtain the plaintext password. Instead, they captured the **NetNTLMv2 challenge-response**, which can later be subjected to **offline password cracking**.

Reconstructing the NetNTLMv2 Hash

To recover the complete NetNTLMv2 hash required by **Hashcat**, multiple values must be extracted from the NTLM negotiation packets.

NTPProofStr

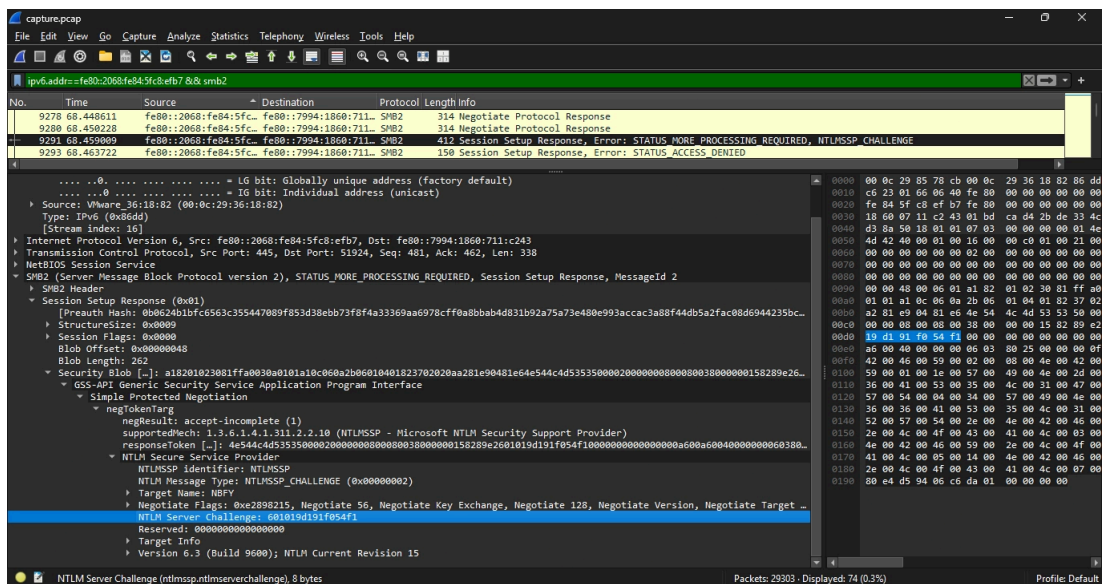
The screenshot displays a Wireshark capture of an NTLMv2 authentication process. The packet list shows a 'Session Setup Request, NTLMSSP_AUTH, User: FORELA\john.deacon' packet. The packet details pane shows the 'NTLMv2 Response' structure, including the 'NTPProofStr' field with the value 'c0cc803a6d9fb5a9082253a04dbd4cd4'. The packet bytes pane shows the raw hex data of the response.

c0cc803a6d9fb5a9082253a04dbd4cd4

Extracted from:

NTLMSSP_AUTH

Server Challenge



601019d191f054f1

Extracted from:

NTLMSSP_CHALLENGE

Username

john.deacon

[illegible]

When constructing the Hashcat input, remove the **first 16 bytes (32 hexadecimal characters)** from the NTLMv2 Response because those bytes are already represented by the **NTProofStr** field.

Hashcat expects NetNTLMv2 hashes in the following format:

```
Username::Domain:ServerChallenge:NTPProofStr:NTLMv2Response
```

Example:

```
john.deacon::FORELA:601019d191f054f1:c0cc803a6d9fb5a9082253a04dbd4cd4:010100000000000080e4d59406c6da01...
```

Save the reconstructed hash to a file:

```
echo "john.deacon::FORELA:601019d191f054f1:c0cc803a6d9fb5a9082253a04dbd4cd4:010100000000000080e4d59406c6da01..." > ntlmsspHash.txt
```

Cracking the Captured Hash

The captured NetNTLMv2 hash was tested against a password wordlist using **Hashcat**.

Example command:

```
hashcat -a 0 -m 5600 ntlmsspHash.txt /usr/share/seclists/Passwords/password.txt
```

Result

The password was successfully recovered:

```
NotMyPassword0K?
```

This demonstrates that although the attacker did not immediately obtain the victim's plaintext password, the captured **NetNTLMv2 challenge-response** could be cracked offline because the password was weak enough to be found in the supplied wordlist.

References

- [TCM Security – LLMNR Poisoning and How to Prevent It](#)

- [John Hammond – LLMNR Poisoning \(YouTube\)](#)
- [ExtraHop – LLMNR Protocol Overview](#)
- [Hack The Box – LLMNR Poisoning Attack Detection](#)